

HACKING THE PLANET

DESENVOLVIMENTO E SEGURANÇA



6

LISTA DE FIGURAS

Figura 1 – Gerenciamento de dispositivos	8
Figura 2 – Utilização do Node-Red	9
Figura 3 – Criação de um <i>dashboard</i>	9
Figura 4 – Arquitetura HPE	11
Figura 5 – <i>Dashboard</i> da plataforma HPE	12
Figura 6 – MindSphere e setores potenciais	13
Figura 7 – <i>Dashboard</i> da plataforma MindSphere.....	14
Figura 8 – Aplicação Node-RED usando Artik.....	18
Figura 9 – Funcionamento do ataque pelo Mirai	23

SUMÁRIO

IOT E A SEGURANÇA	4
1 INTRODUÇÃO	4
2 INDICADORES ESSENCIAIS	5
2.1 Indicadores para a melhor escolha	5
3 EXEMPLOS DE SOLUÇÕES CORPORATIVAS	7
3.1 Dojot.....	7
3.2 HPE Universal IoT Platform.....	10
3.3 Siemens MindSphere	12
3.4 Amazon AWS IoT	15
3.5 Samsung ARTIK.....	16
4 DESENVOLVENDO SOLUÇÕES COM DISPOSITIVOS.....	18
4.1 Segurança de aplicações distribuídas	18
4.2 Por que se preocupar com segurança?	19
4.3 Desafios, ameaças e restrições de segurança.....	21
4.4 Utilização de APIs	25
4.5 Autenticação na IOT	27
4.6 Estratégias para a segurança.....	29
4.7 Algumas boas práticas	31
CONCLUSÃO.....	33
REFERÊNCIAS.....	35

IOT E A SEGURANÇA

1 INTRODUÇÃO

O aprendizado dentro de um ecossistema de **IoT** passa por um processo de maturidade computacional muito intenso, desde o conhecimento de sensores e atuadores até a construção de um gateway que, em linhas gerais, serve como uma ponte entre os dispositivos inteligentes (*smart devices*) e a Internet.

Utilizar um dispositivo que tenha o Arduino como força motriz para o encaminhamento dos dados é um ponto de partida mais recomendado, mas a partir desse ponto, é fundamental que se utilize uma solução corporativa, afinal o mercado exige segurança, escalabilidade e confiabilidade, não havendo espaço para soluções caseiras.

Nesse sentido, selecionar a plataforma certa é fundamental para a transformação de negócios impulsionada pela **IoT**. Vindo ao encontro de tais necessidades, desde agilizar os processos, interromper a concorrência, até descobrir novas maneiras de expandir seus negócios, é importante listar algumas soluções corporativas que entregam resultados mais completos.

Segundo um estudo feito pela Gartner (2014), as plataformas **IoT** como soluções de software devem ser capazes de gerenciar tecnicamente os dados. Além disso, é fundamental saber como definir qual plataforma é a mais adequada para cada negócio, visto que todas as empresas vão precisar de plataformas que garantam flexibilidade e a expansão de seus desenvolvimentos na área. Assim, o estudo aponta três funcionalidades essenciais a uma boa plataforma **IoT**:

- **Suporte a aplicações:** para a customização de soluções **IoT**.
- **Consolidação de dados e armazenamento:** para capturar e armazenar dados e gerar *insights*.
- **Gerenciamento de conectividade:** para conectar automaticamente sistemas, redes e equipamentos.

Outro elemento crucial para a escalabilidade das plataformas **IoT** envolve a integração entre os elementos do ecossistema, e de acordo com Benoit Lheureux, vice-presidente de pesquisas do Gartner:

Alcançar a integração completa para ativos conectados à IoT é provavelmente mais desafiador do que se pensa, porque envolve muitos terminais diferentes da TI. É crucial qualificar as expectativas em torno de uma implementação e assegurar que ela entregará os benefícios esperados (CONVERGÊNCIA DIGITAL, 2017).

Se de um lado existem múltiplas soluções corporativas, do outro, o gestor, o que é chamado de “C level” (CEO, CTO, CMO), deve ter competências e habilidades que sigam de forma equilibrada com essas novas necessidades. Para atender a estas demandas, os líderes de TI corporativos devem:

- desenhar e desenvolver plataformas que sejam extensíveis e abertas para uso de serviços **IoT** externos;
- implementar modelos de precificação que garantam rápido retorno a partir de uma plataforma padronizada;
- buscar o desenvolvimento de novos serviços, como bibliotecas analíticas, monetização de dados, ferramentas de governança e segurança avançada, que fortaleçam sua plataforma.

2 INDICADORES ESSENCIAIS

2.1 Indicadores para a melhor escolha

Como a oferta de aplicações e plataformas é bem vasta, se não houver alguns indicadores, o processo de escolha fica totalmente aleatório e sua incorporação não conseguirá atender as demandas e necessidades da empresa.

Por esse motivo, são apresentados nos itens a seguir alguns indicadores essenciais para facilitar o processo de aquisição.

- **Compatibilidade:** a plataforma deve integrar-se facilmente ao seu sistema de *back-end*. Além da interoperabilidade entre dispositivos, deve haver uma forte comunicação entre aparelhos e sistemas externos. Ele também deve permitir que você use **APIs** ou Interfaces de Programa de Aplicativos para interagir e compartilhar dados com outras empresas.
- **Largura de banda:** em casos normais, existe uma capacidade de terminação e conectividade da plataforma de nuvem para dispositivos que possuem conectividade de largura de banda limitada, provavelmente causada por limitação de infraestrutura. Isso pode acontecer porque as plataformas de **IoT** são executadas em plataformas de nuvem pública, como o Google Cloud e o AWS. A baixa latência e alta largura de banda são necessárias para a movimentação eficiente de informações e comunicações entre os componentes de processamento.
- **Parcerias:** o ecossistema de parceiros da nuvem é algo que é preciso ser considerado ao escolher uma plataforma. Isso depende do valor oferecido pelo parceiro (experiência de domínio, experiência em nuvem, visão estratégica etc.) e a extensão de sua oferta (ofertas de software e hardware).
- **Ferramentas analíticas e preditivas:** razão pela qual temos dispositivos conectados é que podem coletar dados grandes em torno de produtos, empresas, clientes e fluxos de trabalho e usar esses dados para tomar decisões de negócios ou novos lançamentos. Converter dados em *insights* acionáveis é crucial por causa da monstruosidade dos dados que estão chegando. À medida que os dados chegam continuamente de todos os sensores e dispositivos conectados, uma enorme quantidade de dados permanece inexplorada, subutilizada.
- **Customização:** o fornecedor da plataforma deve proporcionar a liberdade de personalização de acordo com suas necessidades. Na maioria dos casos, existem ferramentas para arrastar e soltar, e é altamente recomendável escolher um fornecedor que tenha fluxos de trabalho consistentes.

- **Segurança:** é a principal preocupação ao escolher uma plataforma, cada componente deve ter suas próprias opções de segurança. *Secure Socket Layer* ou SSL, o *gatekeeper* confiável é aquele usado pelas empresas, incluindo os bancos para segurança máxima no nível de acesso à nuvem.

3 EXEMPLOS DE SOLUÇÕES CORPORATIVAS

Em um mundo extremamente dinâmico, as soluções dentro do ecossistema de **IoT** surgem a todo momento. Para que sejam apresentadas algumas soluções, é importante deixar registrado que em um período curto é possível que novas soluções entrem no mercado, fazendo com que as atuais se tornem obsoletas.

A proposta desta seção é a de apresentar e detalhar algumas das soluções existentes, com o objetivo principal de listar as principais características de cada uma e os seus respectivos pontos fracos e fortes.

3.1 Dojot

A plataforma Dojot surgiu com o objetivo de desenvolver e demonstrar tecnologias para as cidades inteligentes (*smart cities*), tendo como pilares de sustentação: segurança pública, mobilidade urbana e saúde. Por ser uma plataforma genuinamente brasileira, foi concebida por uma proposta *open source* para facilitar o desenvolvimento de soluções e o ecossistema **IoT**, com a prerrogativa de atender as características regionais, tendo como principais características (DOJOT, 2020):

- **APIs** abertas permitindo o acesso fácil das aplicações aos recursos da plataforma.
- Armazenamento de grandes volumes de dados em diferentes formatos.
- Conexão e coleta de dados de dispositivos.
- Construção de fluxos de dados e regras de forma visual, permitindo a rápida prototipação e validação de cenários de aplicações **IoT**.
- Processamento de eventos em tempo real aplicando regras definidas pelo desenvolvedor.

Por se tratar de uma solução completa, na visão da empresa, é preciso ter em mãos os dispositivos inteligentes (conectados na rede), e que para o Dojot é uma representação digital para um dispositivo real ou *gateway* com um ou mais sensores ou uma representação para um dispositivo virtual com sensores/atributos inferidos de outros dispositivos.

No sentido de esclarecer melhor como seria feita a conexão entre um dispositivo real e a plataforma, por exemplo, um dispositivo real com sensores térmicos e de umidade pode ser representado dentro do Dojot como um dispositivo com dois atributos (um para cada sensor). Esse dispositivo é chamado de dispositivo regular ou por seu protocolo de comunicação, por exemplo, dispositivo MQTT ou dispositivo CoAP.

O painel de controle da plataforma é web, o que facilita muito o fator de gerenciamento dos dispositivos conectados, como pode ser observado pela (figura abaixo – “Gerenciamento de dispositivos”), além de depender apenas de um navegador como pré-requisito para sua utilização.

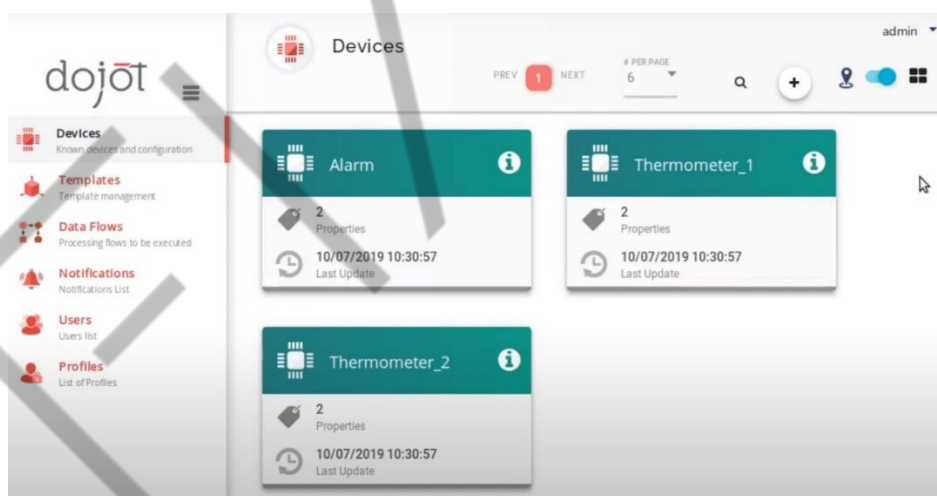


Figura 1 – Gerenciamento de dispositivos

Fonte: <http://www.dojot.com.br/tutoriais-sistemas-iot/> (2020)

A interface de gerenciamento permite que seja utilizado o Node-Red como camada intermediária e todos os fluxos sejam também construídos por ela, conforme pode ser observado na figura – “Utilização do Node-Red”, a seguir.

Com um fluxo, é possível analisar dinamicamente cada nova mensagem para aplicar validações, inferir informações e acionar ações ou notificações, de uma forma simples e intuitiva.

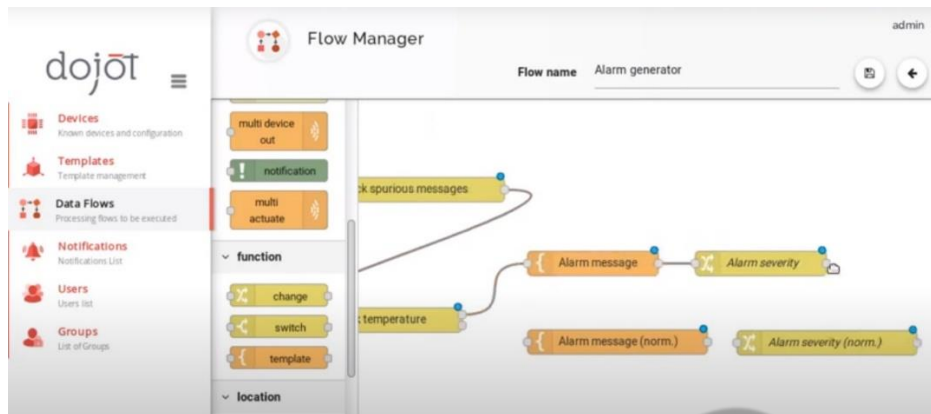
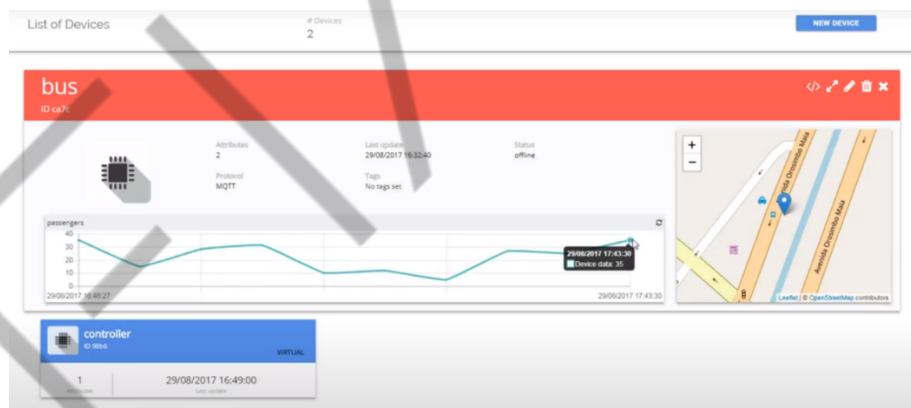


Figura 2 – Utilização do Node-Red

Fonte: <http://www.dojot.com.br/tutoriais-sistemas-iot/> (2020)

Um item a ser considerado é a utilização de elementos do Node-Red para a criação simples de um *dashboard*, que proporciona a visualização de dados de um modo visual e em tempo real, conforme observado na figura – “Criação de um *dashboard*”.

Para o desenvolvimento de aplicações mais sofisticadas, a empresa pode seguir com a linha de raciocínio de utilizar na camada de *front-end* o Node.js, completando todo o ciclo relativo à solução customizada propriamente dita.

Figura 3 – Criação de um *dashboard*

Fonte: <http://www.dojot.com.br/tutoriais-sistemas-iot/> (2020)

Falando em integração, como seria o processo de integrar uma “aplicação legada” com a plataforma Dojot? Seria bastante simples e direto, basta seguir os seguintes passos recomendados pelo fabricante:

- **Recuperando dados históricos:** caso seja necessário, periodicamente, ler todos os dados históricos relacionados a um dispositivo, deve ser feito usando **API** fornecida.

- **Assinando eventos relacionados a dispositivos:** se o seu aplicativo puder “escutar” eventos, seu aplicativo precisará assinar os tópicos via MQTT, que podem ser criados usando também uma **API**.
- **Usando *mashup* (aplicação web que usa conteúdo de mais de uma fonte para criar um novo serviço completo) para pré-processar dados:** se você quiser fazer algo mais, pode usar fluxos que ajudem a processar e transformar dados para que possam ser enviados adequadamente para a aplicação legada por solicitação HTTP, por e-mail ou armazenados em um dispositivo virtual (que pode ser usado para gerar notificações).

3.2 HPE Universal IoT Platform

Por meio da “Universal IoT Platform”, a *Hewlett Packard Enterprise (HPE)* permite às empresas a aquisição de uma solução vertical e independente, com escalabilidade, modularidade e versatilidade. Isso permite que os clientes gerenciem suas soluções de **IoT** e forneçam valor por meio da monetização da grande quantidade de dados gerados por dispositivos conectados e disponibilizá-los aos aplicativos legados.

Além da conectividade onipresente, a “*HPE Universal IoT Platform*” fornece toda a base para o gerenciamento de dispositivos e serviços, aquisição de dados e exposição a aplicativos. Somado a estes fatos, a plataforma fornece suporte para ecossistemas inteligentes e pode ser implantada nas instalações locais, bem como em qualquer ambiente de nuvem, para um modelo genérico como serviço.

A plataforma permite a descoberta, configuração e gerenciamento de software e facilita pontos de controle em dados, para que seja possível gerenciar remotamente milhões de dispositivos **IoT** e aplicações inteligentes na mesma plataforma. Observe pela figura – “Arquitetura HPE” – um bom exemplo da arquitetura da plataforma.

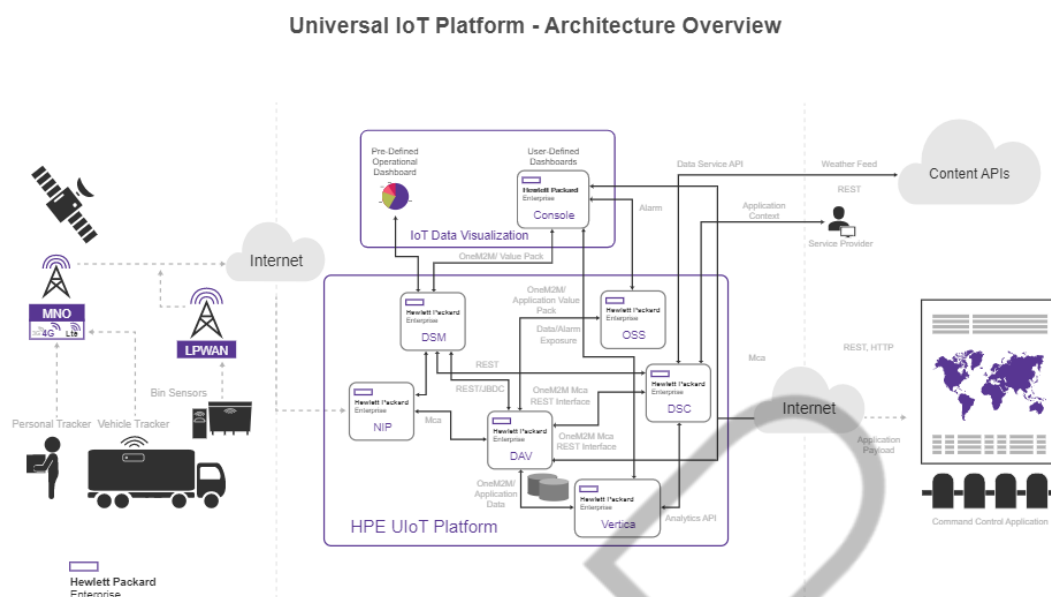


Figura 4 – Arquitetura HPE
Fonte: CLOUD28 (2020)

Além disso, é independente de fornecedor de dispositivo e de conectividade. A solução opera a um baixo TCO com alta escalabilidade e flexibilidade ao combinar o modelo de dados integrado com padrões M2M (*Machine to Machine*). Também apresenta segurança incorporada diretamente na base, permitindo proteção de ponta a ponta ao longo do ciclo de vida dos dados.

Em termos de escalabilidade, é fundamentalmente projetada para suportar milhões de conexões com dispositivos heterogêneos, e modular ao ponto de ser implantado como tal, onde somente os módulos principais necessários podem ser adquiridos como licenças ou como serviço, com uma opção para adicionar módulos avançados, conforme necessário.

Com o intuito de fornecer alguma tela da plataforma, observe na figura – “*Dashboard da plataforma HPE*” – como os dados podem ser organizados de um modo tão sofisticado e visual, para a constituição de uma ferramenta analítica poderosa para as empresas.

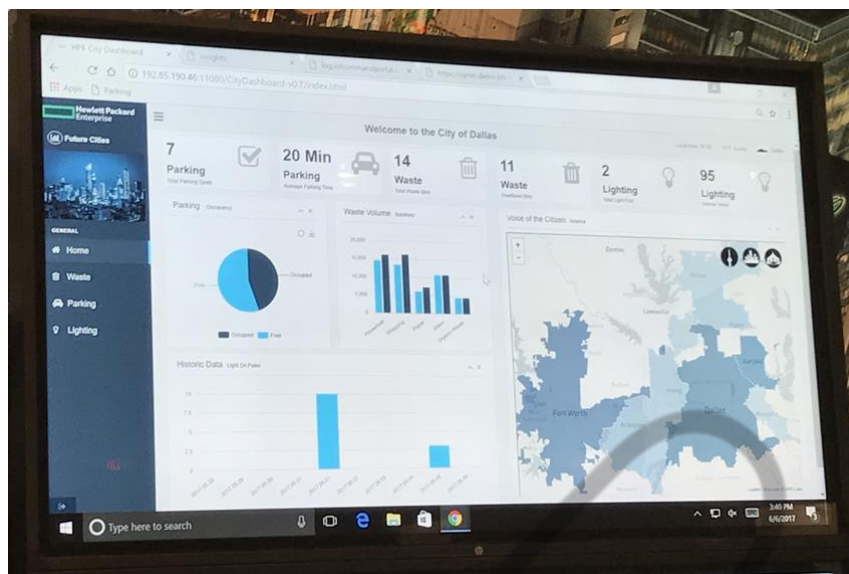


Figura 5 – Dashboard da plataforma HPE
Fonte: CLOUD28 (2020)

Como um bom exemplo de parcerias estratégicas, a HPE está fazendo uma parceria com a *Tata Communications* para converter a "Cidade do Aço" de Jamshedpur em Jharkhand, na Índia, para uma cidade inteligente, e está também formando uma parceria com a PwC (parceira de aliança estratégica global de longa data) para oferecer a plataforma para suportar iniciativas de desenvolvimento, teste e gerenciamento de aplicativos **IoT** no "*Smart Cities Experience Center*" da PwC.

3.3 Siemens MindSphere

O MindSphere (sistema operacional aberto), baseado na nuvem e criado pela empresa Siemens, conecta as coisas reais ao mundo digital e permite alto valor baseado na indústria aplicações e serviços digitais para impulsionar os negócios. Como a plataforma é aberta (*Platform as a Service* ou PaaS), permite um ecossistema de parceiros, incluindo parceiros de soluções, desenvolvedores de aplicativos e conectividade, além de parceiros para oferecer soluções inovadoras de **IoT**.

A Siemens, responsável pela criação da plataforma, está trabalhando lado a lado com aproximadamente 20 empresas parceiras, com o objetivo de fundar a "MindSphere World", uma organização mundial dos seus respectivos usuários.

Tal organização foi projetada para oferecer suporte a seus membros individuais no desenvolvimento e aprimoramento de soluções de **IoT** na plataforma e na exploração de novos mercados na economia digital, o que incluirá sugestões sobre os

requisitos colocados no sistema operacional e recomendações sobre a definição de regras uniformes para a utilização de dados. Outro papel da organização será o de promover a ciência, a pesquisa e o ensino no ambiente do próprio MindSphere.

Segundo Bruno Geiger, CTO da empresa Eisenmann:

A estrutura aberta da MindSphere oferece uma ampla gama de benefícios para nós como usuários, em especial devido à ligação independente de fabricantes e fábricas e também quando se trata do desenvolvimento de aplicativos. No âmbito do MindSphere World, agora também podemos conversar com outros usuários sobre maneiras pelas quais as tecnologias disruptivas estão mudando a face da economia em geral, e sobre o potencial de negócios resultante que poderia ser utilizado para soluções baseadas em IoT (SIEMENS, 2018).

Um dos pontos importantes para se destacar da plataforma é a diversidade das potenciais aplicações, como pode ser observado pela figura – “MindSphere e setores potenciais”, indicando o seu grau de interoperabilidade intrínseco.

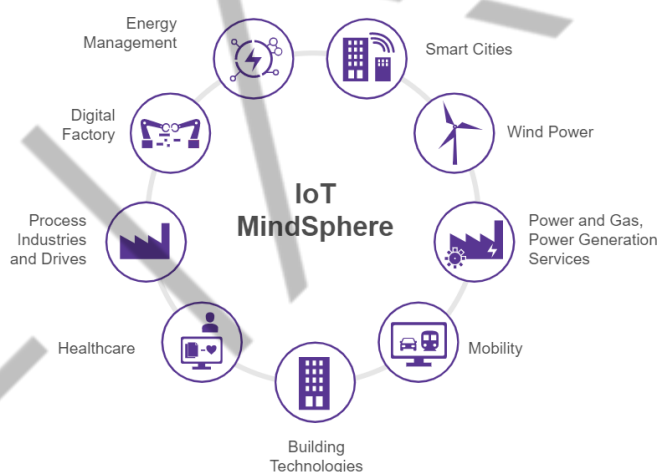


Figura 6 – MindSphere e setores potenciais

Fonte: Machining News (2020)

Com a integração perfeita de dados operacionais em toda a cadeia de valor, as empresas não só impulsionam a transparência operacional, mas também comparam resultados de simulação e teste com observações do mundo real para ganhar vantagem competitiva.

A digitalização e a transformação dos dados da **IoT** em resultados de negócios produtivos são os principais impulsionadores do MindSphere. Somado a tal fato, as empresas podem aproveitar a plataforma para fechar o ciclo por intermédio da ideação, realização e utilização de produtos para integrar dados operacionais em toda

a cadeia de valor, não apenas impulsionando a eficiência operacional, mas também comparando resultados de simulação e testes com observações do mundo real.

Como parte de uma estratégia completa de digitalização, permite novas maneiras de resolver problemas que as empresas considerem novos modelos de negócios inovadores. É possível desenvolver, implantar e executar serviços digitais imediatamente, criar os próprios aplicativos ou até mesmo novos modelos de negócios.

Em termos de interface, pela figura – “*Dashboard* da plataforma MindSphere” – é possível perceber o potencial analítico da ferramenta de visualização de dados, de forma simples e transparente.

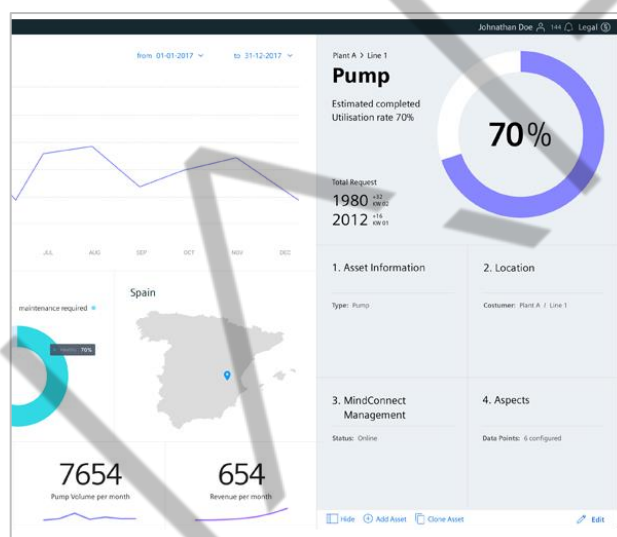


Figura 7 – *Dashboard* da plataforma MindSphere
Fonte: Mindsphere (2020)

A segurança é uma das principais prioridades da Siemens, uma das principais empresas fornecedoras de automação do mundo, com aproximadamente 30 milhões de sistemas automatizados, 75 milhões de contadores inteligentes contratados e um milhão de produtos conectados no campo.

O quadro de segurança da plataforma está alinhado aos princípios padrões da indústria (IEC 62443, ISO / IEC 27001) e recomendações governamentais para manipulação de dados em ambientes de nuvem.

3.4 Amazon AWS IoT

A Amazon AWS **IoT** é uma plataforma de nuvem que permite conectar e gerenciar dispositivos variados, possibilitando a criação de aplicações **IoT** para coletar, analisar e gerenciar dados e para enviar comandos para os dispositivos da nuvem. Foi criada em 2006 para oferecer serviços de infraestrutura de TI para empresas por meio de nuvem na web, reduzindo custos de aquisição de servidores e agilizando a rodagem de dados e resultados. Os data centers estão localizados nos EUA, Europa, Brasil, Cingapura, Japão e Austrália.

Existem algumas características que indicam vantagens competitivas e merecem um destaque:

- Permite conectar e gerenciar dispositivos utilizando protocolos que servem facilmente para tolerar diversas conexões prolongadas, diminuir códigos nos dispositivos e otimizar recursos de banda larga.
- Disponibiliza autenticação e criptografia nos diferentes pontos de conexão, mantendo em segurança todas as pontas de acesso. Ainda é possível customizar as permissões por níveis de acesso.
- É possível filtrar e intervir sobre os dados de acordo com as regras de negócio definidas previamente.
- Ele também armazena o estado mais recente do dispositivo, mesmo que ele não esteja online. Desta forma, o aplicativo pode ler o dispositivo mesmo se não estiver conectado a rede.

Como parte do processo do conhecimento do produto, é interessante também listar alguns clientes que fazem uso de produtos da AWS:

- **Bigfinite**: uma empresa que fornece soluções para a indústria farmacêutica e de biotecnologia que abrange toda a cadeia de produção, desde a pesquisa e desenvolvimento até a distribuição de medicamentos.

Utilizou a AWS para construir uma plataforma chamada *Bengegine* que analisa diferentes fontes de dados e gera *insights* para melhorar a produtividade de produtos em conformidade.

- **Amway:** líder em vendas diretas de produtos nutricionais, de beleza e para casa no mundo, começou a investir em **IoT** quando decidiu incluir dispositivos de bluetooth e wi-fi em um sistema de tratamento de ar. A escolha pela AWS foi justamente pela abrangência global que permitia a empresa implementar o produto em vários locais pelo mundo.
- **Chai Point:** uma das maiores varejistas de chá da Índia que também oferta seus produtos pela Amazon.in. Além disso, também oferece soluções habilitadas para **IoT**, como máquinas de venda automática fáceis de controlar e monitorar por qualquer dispositivo conectado.

3.5 Samsung ARTIK

A empresa Samsung possui uma visão estratégica muito apropriada e direcionada ao ecossistema de **IoT**, como afirma HyunSuk (HS) Kim, Presidente da Samsung Consumer Electronics e da Samsung Research:

“Na Samsung, acreditamos que a Internet das Coisas deve ser fácil como apertar um botão. Com os novos produtos e serviços anunciados, estamos tornando a IoT mais fácil, mais transparente. Estamos comprometidos em acelerar a adoção da IoT por todos e levar inteligência a todos os dispositivos Samsung conectados até 2020. Esses avanços vão ajudar os consumidores a perceber os benefícios de uma vida conectada simples e integrada” (SAMSUNG, 2018).

Nesse sentido, a plataforma ARTIK Smart **IoT** da Samsung foi projetada desde o início para lidar com evoluções cada vez mais aceleradas em conectividade do dispositivo. Os módulos são sistemas integrados concebidos para a Internet das Coisas. Eles são projetados para fornecer rapidamente uma gama completa de aplicativos **IoT** com a capacidade de integração com o Artik Cloud ou qualquer outro serviço de nuvem. Os módulos Artik também podem ser dimensionados do desenvolvimento para a produção com facilidade.

Os modelos de lançamento atuais variam desde a placa Artik 1, uma placa de sensor **IoT** de baixa potência até os módulos Artik 520, Artik 710 e Artik 1020 que possuem mais capacidade e capacidade de processamento.

Embora tenha muitos atributos, o Samsung Artik tem três principais diferenciais:

- **Capacidades avançadas de segurança:** tanto dispositivos quanto aplicativos de terceiros, é possível conectá-los com segurança à nuvem usando protocolos seguros. A maioria dos módulos adiciona segurança baseada em hardware para armazenar certificados e chaves, que compartilham uma raiz de confiança com a nuvem, e favorecendo a proteção dos dispositivos e dados contra picos de tráfego inesperados ou não autorizados, além das interações de dispositivos, aplicativos e usuários com os padrões abertos baseados na Internet autenticação e autorização.
- **Interoperabilidade de dispositivos e dados:** ARTIK Cloud, uma plataforma de troca de dados aberta, é o caminho mais rápido para conectar dispositivos em silos e ativar novos serviços e aplicativos, fornecendo um modo fácil de usar **APIs**, SDKs e ferramentas para coletar, armazenar e agir com segurança em qualquer dado de qualquer dispositivo conectado ou serviço na nuvem. Usando **APIs** e ferramentas de nível empresarial, as empresas podem gerenciar facilmente sua frota de implementos dispositivos, levam rapidamente a novas soluções e serviços de **IoT** para o mercado e, naturalmente, motivando a expansão dos seus negócios.
- **Time-to-Market e simplicidade:** fornecer a unificação eficiente de hardware, software, nuvem, segurança e parceria em uma única oferta integrada significa que o tempo médio de implementação para ARTIK projetos é de 6 a 9 meses, o que é até quatro vezes mais rápido do que a média da indústria (24 meses). Isso permite para as empresas trazer rapidamente as soluções **IoT** para o mercado e explorar os fluxos de receita para crescer rapidamente o negócio. Não só é economizado tempo considerável na implementação, como também é mais rentável, uma vez que o tamanho das equipes necessárias para integrar os produtos ARTIK é muito menor em comparação com a maioria dos concorrentes.

É interessante observar que em muitas plataformas o padrão relacionado com a parte de cloud está diretamente associada com o uso de fluxos em Node-RED, como é o caso da Artik. Com o intuito de exemplificar, conforme ilustra a figura – “Aplicação Node-RED usando Artik” –, por meio do FRED (um Node-RED baseado em nuvem) conectar os módulos de hardware para controle remoto e visualização.

Como é possível observar pela figura, o fluxo Node-RED em execução no serviço em nuvem (FRED) se comunica diretamente com um fluxo Node-RED em um módulo Artik, que por sua vez grava nos pinos de entrada e saída do Artik usando os nós Node-RED, para ligar e desligar um LED, consultar o status de um *switch*, ler o valor da tensão analógica e controlar um motor, tudo a partir da nuvem.

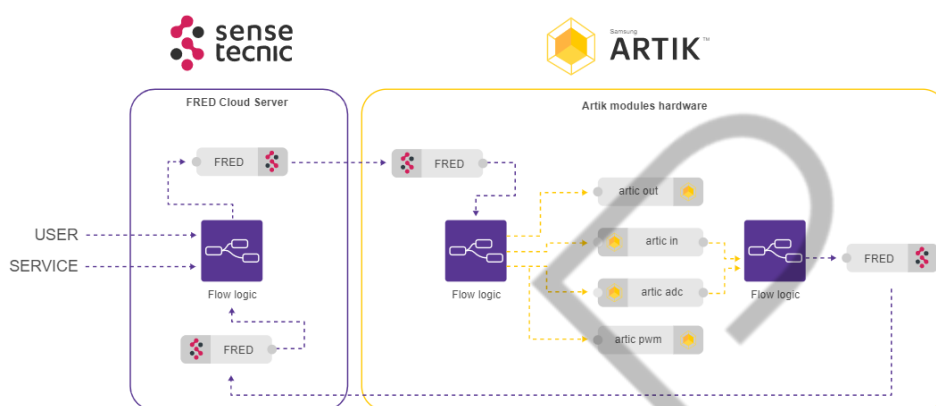


Figura 8 – Aplicação Node-RED usando Artik
Fonte: Sense Tecnic (2016)

Os nós FRED facilitam a conexão de dispositivos ao FRED, depois de configurados e executados, é possível conectar um fluxo em qualquer dispositivo que termine com um nó FRED, e as mensagens são enviadas automaticamente para um nó de entrada FRED na nuvem. Com esses nós, é permitido criar fluxos que abrangem dispositivos e nuvem.

4 DESENVOLVENDO SOLUÇÕES COM DISPOSITIVOS

4.1 Segurança de aplicações distribuídas

A Internet das Coisas (**IoT**) visa melhorar a vida das pessoas e aumentar a interconectividade de uma maior variedade de dispositivos inteligentes incorporados usando os componentes de infraestrutura da Internet existente.

Isso permite comunicações entre sensores em eletrodomésticos, telefones, carros, notebooks, maquinários de fábrica e muitos outros dispositivos que são capazes de acesso à rede por meio de protocolos como 3G, Wi-Fi, Bluetooth e ZigBee.

As empresas Gartner e Cisco avaliam a **IoT** como uma tecnologia promissora do futuro, assim como a maioria das demais também concorda que a **IoT** se tornará

um ponto chave para seu crescimento e perenidade nas próximas gerações. De acordo com a *International Data Corporation* (IDC), a escala de mercado deve crescer de US \$ 655,8 bilhões em 2014 para US \$ 1,7 trilhão em 2020 com um aumento anual de aproximadamente 17% (IDC, 2017).

Assim, muitas corporações no mundo estão desenvolvendo soluções com dispositivos, serviços e tecnologias relacionados à **IoT** para antecipar e dominar o mercado com mais antecedência. No entanto, elas não consideraram a segurança como um requisito funcional, e com o fator segurança se tornando menos importante as preocupações com o termo segurança fez com que ele ficasse em último na lista de prioridades, de tal forma que as mesmas relutam em aplicar a segurança desejável aos dispositivos e serviços.

Embora essas preocupações não possam influenciar a adoção *a priori* de uma tecnologia “A ou B”, se os problemas reais de segurança não forem resolvidos e as aplicações **IoT** desenvolverem uma reputação de insegurança, é bem provável que isso afete negativamente a sua adoção em um longo prazo e impeça que a tecnologia efetivamente se estabeleça. Por esses motivos, é importante entender os riscos de segurança e as ações do usuário (consumidor) com relação a ela, a fim de torná-la compatível em aplicações **IoT** do mundo real.

É importante também saber quando os usuários podem aceitar níveis reduzidos de segurança ou estão dispostos a colocar mais esforço em adquirir suas aplicações mais seguras, a fim de obter o equilíbrio, por exemplo, entre o design da interface, que é particularmente importante para aplicativos **IoT**, e uma funcionalidade trivial como a conexão de nós (nodes), a qual requer forte interação do usuário em termos operacionais.

4.2 Por que se preocupar com segurança?

Toda nova tecnologia ou tecnologia emergente traz consigo novos benefícios, assim como novos riscos e desafios, e pelo fato de que está intimamente relacionada à comunicação e à informação, justifica-se considerar os desafios de segurança e privacidade conhecidos e examinar como as preocupações são transferidas para o estado atual e futuro da **IoT**.

Comparando-se com os mecanismos de segurança da informação conhecidos, existem muitas semelhanças e diferenças sutis, porém algumas características tornam a segurança e a privacidade desafios da **IoT** tão distintos que é pertinente uma investigação mais cuidadosa e criteriosa no assunto, principalmente no que se refere à exploração de vulnerabilidades.

Os problemas de segurança e privacidade no ecossistema da **IoT** não aumentam linearmente com o número de conexões dispositivos, e sim crescem em um ritmo muito mais rápido. Isso se deve ao fato de que, mesmo assumindo que tudo é igual, o número de canais de comunicação em uma rede aumenta mais rápido que o número de nós (um ponto de conexão, seja um ponto de redistribuição ou um terminal de comunicação).

Espera-se que a **IoT** seja bem mais heterogênea do que as atuais redes de computadores, integrando uma grande variedade de dispositivos de diferentes fabricantes, plataformas de software e comunicação protocolos. Na arquitetura atual de redes, enquanto servidores e estações de trabalho são protegidos em data centers e escritórios, computadores pessoais, notebooks e dispositivos portáteis são protegidos pela presença do proprietário, em uma configuração de **IoT**, sensores e outros dispositivos estão localizados em todos os lugares e expostos a roubo e danos maliciosos.

Um outro ponto a ser considerado como vulnerável é que os dispositivos **IoT** são geralmente sistemas acionados por bateria, propensos a falhas e há menor poder de processamento e memória, o que dificulta o cumprimento dos requisitos para a implementação de segurança apropriada, pois estes exigem uma quantidade considerada de recursos de processamento e memória.

Embora nos últimos anos isso tenha sido um problema menor, muitas construções ainda têm a ausência de funcionalidades de segurança embutidas.

À medida que o número de coisas conectadas aumenta, em diferentes bases de dados, aumentam os riscos continuamente. Embora tais dados confidenciais possam ser removidos ou protegidos anonimamente, quando os dados são divulgados, uma combinação imprevisível de dados aparentemente não sensíveis e de diferentes fontes podem criar um identificador único que resulta em violações de privacidade.

Enquanto até recentemente os ataques cibernéticos ameaçavam principalmente computadores, redes de computadores e computadores pessoais, a **IoT** impulsionou os riscos de segurança para um nível superior. Na era da **IoT**, como atuadores e sistemas de controle serão interligados com outros sistemas, atacantes podem ser capazes de direcionar diretamente os dispositivos conectados e promover a destruição física dos equipamentos e infraestruturas, tais como automóveis autônomos, casas inteligentes, redes elétricas, campos petrolíferos, sistemas de transporte e plantas.

A **IoT**, inerentemente, tem uma característica dinâmica e dispositivos difusos como *wearables* que podem entrar e sair da rede **IoT** a qualquer momento. Tal fato, em combinação com características de comunicação por diversos protocolos, torna as medidas tradicionais de segurança da informação insuficientes para a **IoT**.

Um outro fator que precisa ser observado em projetos **IoT** é a coleta dos dados em diversos dispositivos sobre os usuários e seu ambiente para fornecer algum tipo de serviço. Esses dados coletados são normalmente processados em provedores de serviços que estão localizados fora do controle dos usuários. A identificação do usuário é a ameaça de associar um identificador (por exemplo, nome, endereço), com dados privados sobre um indivíduo. Torná-los anônimos, ou seja, a substituição de informações pessoais por **IDs** gerados exclusivamente, não é suficiente para garantir o anonimato dos usuários e tem sido demonstrado que a identidade dos usuários pode ser inferida a partir dos conjuntos de dados anônimos.

Diante de tantos fatos e argumentos substanciais, fica muito claro que a preocupação com a segurança não somente deve existir como também deve utilizar as boas práticas, envolvendo protocolos, processos de autenticação e criptografia que tornem as aplicações efetivamente seguras ou em um nível confiável. Para que isso seja possível, é fundamental conhecer todas as peças do “quebra-cabeça” que compõem o ecossistema da **IoT**.

4.3 Desafios, ameaças e restrições de segurança

É muito importante garantir que haja disponibilidade contínua dos dispositivos baseados em **IoT** para que sejam evitadas possíveis falhas nas operações e

interrupções nos serviços corporativos. Até mesmo para tarefas simples, como a adição de novos pontos de extremidade à rede ou novos dispositivos, a empresa deve considerar alguns dos ataques que podem ser realizados em tais dispositivos. Espera-se com isso que a empresa apresente medidas para garantir que existe inicialmente segurança física para impedir qualquer acesso não autorizado aos dispositivos que estão localizados dentro do perímetro de segurança.

Os ataques cibernéticos disruptivos, como os de negação de serviço (DDOS), podem ter consequências terríveis para a empresa, pois se milhares de dispositivos **IoT** tentarem acessar um determinado site cujos dados não estão mais presentes, os clientes podem ficar frustrados e, conseqüentemente, levar à sua perda, além de uma aceitação ruim do mercado, culminando com a perda de receita.

Existe um caso que ficou bastante conhecido mundialmente e que foi responsável por um ataque, em 2016, por intermédio de um *botnet* que derrubou os principais sites por meio da enorme distribuição de negação de serviço, usando centenas de milhares de dispositivos da **IoT** comprometidos, conhecido como Mirai.

Em essência, o Mirai é um *worm* autopropagado, ou seja, é um programa mal-intencionado que se replica ao localizar, atacar e infectar dispositivos de **IoT** vulneráveis. Ele também é considerado um *botnet* porque os dispositivos infectados são controlados por meio de um conjunto central de servidores de comando e controle (C&C). Esses servidores informam aos dispositivos infectados quais sites atacar em seguida.

O módulo de ataque é responsável por realizar ataques DDoS contra os alvos especificados pelos servidores C&C, e implementa a maioria das técnicas DDoS de código, como inundação HTTP, inundação UDP e todas as opções de inundação TCP. Essa ampla gama de métodos permitiu que a Mirai realizasse ataques volumétricos, ataques de camada de aplicativos e ataques de exaustão de estado de TCP.

Observe como funciona o módulo de ataque na figura "Funcionamento do ataque pelo Mirai", que em seu primeiro dia havia infectado 65.000 dispositivos, até chegar ao ponto máximo em novembro de 2016, com a impressionante marca de aproximadamente 600 mil dispositivos **IoT** infectados.

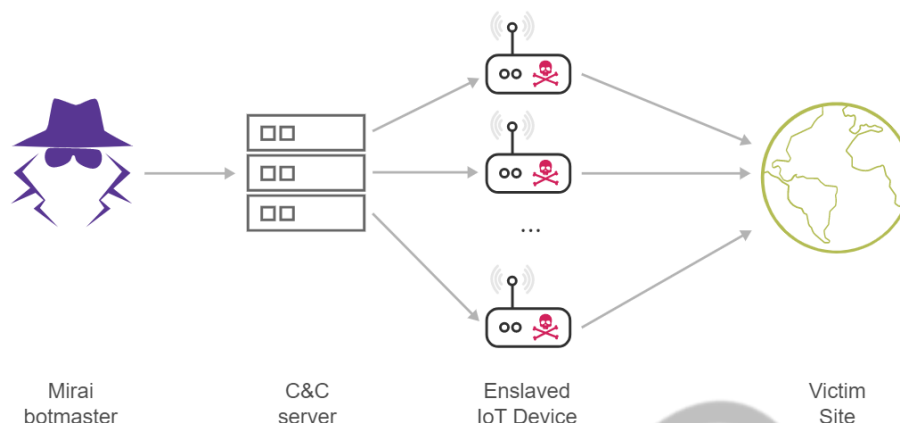


Figura 9 – Funcionamento do ataque pelo Mirai
Fonte: Mirai (2017)

A apresentação do caso Mirai foi o ponto de partida para a discussão de pontos de vulnerabilidade nas redes **IoT**, e é exatamente isso que acontece no mundo real, onde as tentativas de ataques acontecem a todo momento. Em alguns casos, a vida das pessoas corre um risco bastante alto também. Mas como assim? Imagine a situação em que esteja sendo usado um termostato para manipulação de leituras de temperatura em uma usina nuclear. Caso os atacantes ganhem acesso ao dispositivo e, em seguida, o comprometem, então as consequências poderiam ser graves.

Para que seja possível mitigar os riscos, um projeto com dispositivos **IoT** deve ser projetado tendo em mente a segurança, com os mecanismos de controle incorporados.

Por exemplo, pode ser possível que a organização esteja usando dispositivos de hardware e software que eles nunca usaram antes, isto é, absolutamente novo e, ainda assim, os tipos de ataques também podem ocorrer do mesmo modo. É como se fosse uma perseguição infundável entre “mocinhos e bandidos”.

No mundo real, as empresas geralmente enfrentam desafios quando tentam descobrir como devem corrigir rapidamente as vulnerabilidades do dispositivo **IoT** e como deve ser priorizada a ordem de resolução. Na maioria desses dispositivos **IoT**, é necessária uma atualização de *firmware* para que as vulnerabilidades sejam corrigidas e realizar isso em tempo real pode ser bastante desafiador.

Um ponto de vulnerabilidade bastante explorado, neste caso, está relacionado com as credenciais padrão que são fornecidas quando os dispositivos **IoT** são usados pela primeira vez. Em diversas situações, dispositivos como impressoras e os pontos de acesso sem fio sempre vêm com **IDs** de usuário e senhas padrão, facilitando o

ataque. Portanto, a recomendação é a de que logo após a aquisição dos dispositivos, seja feita a alteração dos usuários e senhas que vêm na “configuração de fábrica”.

E se o ponto de vulnerabilidade está diretamente relacionado não com os dispositivos e sim com o processo de comunicação entre eles? Existe algum modo de torná-lo seguro? A resposta é sim e está diretamente associada com algoritmos de criptografia, particularmente aqueles envolvidos com o conceito de chave pública e privada.

Com o uso dos esquemas existentes de criptografia de chave pública, é possível, convenientemente, verificar a integridade e autenticidade do conteúdo digital. Integridade, neste caso, é uma indicação de que o conteúdo digital não foi modificado desde a época de sua criação. Autenticidade significa que o conteúdo digital foi liberado para a pessoa correta. Essas duas características são fornecidas pela assinatura digital e é necessário para que os dispositivos eletrônicos confiem no conteúdo digital.

O “*message digest*” é um mecanismo que é altamente usado para garantir integridade do conteúdo digital, construído por meio de um algoritmo *hash* seguro. E para obter um algoritmo de *hash* seguro, basta forjar algum conteúdo digital que produzirá um valor de *hash* predefinido.

Observe que dois conteúdos digitais diferentes e aleatórios produzirão diferentes valores de *hash*. A probabilidade de ter dois conteúdos digitais diferentes dando valor de *hash* semelhante é zero. Além disso, se uma alteração for feita em alguns *bytes* do conteúdo digital, seu valor de *hash* associado será alterado. Ao contrário do **CRC** (*Cyclic Redundancy Check* ou Verificação de Redundância Cíclica), é impossível adicionar alguns *bytes* ao conteúdo digital que foi modificado para que o valor de *hash* resultante corresponda ao valor original, e que por sua vez que foi para o conteúdo digital não modificado.

O esquema de assinatura digital de chave pública é usado com a finalidade de garantir a autenticidade do conteúdo digital. No caso, é usado um par de chaves, uma chave privada que é secretamente armazenada e utilizada para assinar o conteúdo e uma chave pública que qualquer um pode acessar.

A pessoa que emite o conteúdo digital usará sua própria chave privada para se identificar como o emissor. Qualquer pessoa pode usar a chave pública para verificar

assinatura do conteúdo digital. As duas chaves devem ser “amarradas juntas”. Uma vez que o conteúdo foi assinado com uma chave privada, uma assinatura digital será produzida, o que será verificável pelo uso de uma chave pública. Isso também significa que se qualquer um é capaz de verificar uma assinatura usando uma chave pública, então existe sem dúvida que uma chave privada foi usada para assiná-lo.

Apresentado o conceito de criptografia e certificado digital, como esses conceitos se relacionam para deixar o processo de comunicação de dispositivos **IoT** mais seguro? No caso os certificados permitem que as chaves assimétricas sejam usadas com os dispositivos, o que significa que as chaves privadas são gravadas de forma segura em um dispositivo. Dessa maneira, o material confidencial de criptografia nunca deixa o dispositivo. Além de tudo, os certificados fornecem opções mais fortes de autenticação de cliente em outros esquemas, como nome de usuário e senha ou *tokens*, também pelo fato de que a chave secreta nunca deixa o dispositivo.

O conteúdo que foi apresentado é apenas a “ponta de um iceberg” e precisa ser mais bem explorado com detalhes caso haja a necessidade de investigar mais a fundo os pontos de vulnerabilidade que podem ser explorados pelas ameaças. O próximo passo é entender de que forma é possível criar uma “redoma” para isolar as aplicações **IoT** por meio das **APIs**, o próximo assunto.

4.4 Utilização de APIs

As **APIs** (*Application Programming Interfaces* ou Interface de Programação de Aplicativos) estão fortemente ligadas à **IoT**, pois permitem a exposição com segurança dos dispositivos conectados a clientes, canais de entrada no mercado e outros aplicativos na infraestrutura de TI local. Como as **APIs** conectam importantes “coisas” como carros, dispositivos médicos, redes inteligentes e termostatos ao ecossistema, é essencial implantar o gerenciamento de **APIs** por ser flexível, escalável e, acima de tudo, seguro.

O gerenciamento de **API** é um grande arcabouço tecnológico sobre o qual estão agrupados uma coleção de soluções – como *gateways*, segurança e gerenciamento de acessos – cada um com o seu próprio cenário de potencial desastre caso as coisas não saiam conforme planejado.

Acredita-se que as **APIs** serão a principal maneira de permitir interações entre objetos que foram conectados à Internet e parte do que torna a **IoT** tão importante é a habilidade de conectar aplicações a dispositivos, seja individualmente ou agregados, e tudo isso só seria possível com as tais **APIs**.

Existem diversos exemplos de **APIs** dentro da categoria Internet das Coisas, por esse motivo serão listadas algumas delas, ficando como recomendação a seguinte referência para estudos futuros (IOT-API, 2020). Esta referência, por sinal, disponibiliza as especificações para que as mais de 300 **APIs** listadas possam ser devidamente categorizadas e comparadas, servindo como um instrumento bastante útil para a sua avaliação.

Como o número de possíveis **APIs** é praticamente impossível de ser listado aqui, serão detalhadas algumas delas, de forma pontual e direta:

- **Netbeast**: faz uso do painel de controle automatizado com o objetivo de sincronizar as funcionalidades das aplicações e dispositivos **IoT**. Suporta os recursos de hospedagem do sistema operacional para os dispositivos embarcados como o Raspberry Pi, sendo capaz também de suportar várias plataformas, como Windows e Linux. Tecnicamente, as solicitações e as respostas são transmitidas em um formato padrão JSON (*Javascript Object Notation*).
- **Space Bunny**: usada principalmente para fins de monitoramento de fluxos ao vivo e no controle de dispositivos que estão localizados remotamente. Algumas das características desta **API** incluem o gerenciamento de usuários, filas de mensagens e separação de fluxo de dados. Suporta muito o desenvolvimento de aplicações industriais e casas inteligentes. A troca de informações nesta **API** é feita no formato JSON e usa as chaves da **API** para fins de autenticação.
- **Kaa Admin**: é uma **API** bem interessante, pois permite que os desenvolvedores integrem seus próprios aplicativos dentro do ecossistema. Um ponto importante é a possibilidade de interconexão com a nuvem, sob a qual os usuários podem estabelecer uma conexão para o gerenciamento de seus dispositivos, produtos inteligentes, protótipo, coleta e, em seguida,

analisar dados em tempo real, dimensionar as soluções de **IoT** e estar em posição de implantar as soluções em qualquer outro lugar.

- **Samsung ARTIK**: é uma plataforma aberta para troca de dados, foi projetada para trazer ordem ao caos e quebrar paradigmas. Permite coletar, armazenar e executar uma ação em qualquer dado de qualquer serviço ou dispositivo em nuvem. Unifica hardware, software, nuvem, segurança e ecossistema de parceiros em uma única oferta integrada. Além disso, permite também aos desenvolvedores criarem aplicativos e serviços com facilidade usando um número de SDKs móveis e de plataforma: Objective C / iOS, Java / Android, JavaScript, Swift, PHP, Python, Ruby, Scala, C # e Tizen 3.0.
- **Weaver**: esta **API** fornece aos desenvolvedores ferramentas usando o frameworks e serviços da “*Weaver of Things*”, permitindo manipular vários dispositivos, independentemente do fornecedor ou marca, fator bastante recomendável em um ambiente heterogêneo. Fornece também aos desenvolvedores um sistema efetivo, fácil de usar, econômico e escalável.
- **Mnubo**: é uma plataforma para análise que visa melhorar diferentes tipos de hardware pela extração de valor dos dados do sensor. Esta tarefa é realizada pela coleta de dados de objetos que foram processados em um ambiente de nuvem com o objetivo de fornecer uma visão estratégica.
- **Axway 5**: é uma solução de entrega e governança de **API** com o objetivo de desbloquear qualquer dispositivo conectado, permitindo a coleta dos dados dos dispositivos/sensores e as ações de integração facilmente consumidas pelo aplicativos móveis, sistemas internos e parceiros externos.

4.5 Autenticação na IOT

Com a introdução de dispositivos inteligentes, os hackers começaram a desenvolver mecanismos que lhes permitam roubar dados valiosos das empresas, e dentro do ecossistema da IoT, o processo de autenticação do usuário é ainda mais sensível aos ataques.

Imagine um aplicativo que pode auxiliar no desbloqueio de um automóvel usando o celular. Neste caso é preciso ter a absoluta certeza de que é o proprietário que está realizando o processo, pois somente ele será capaz de desbloqueá-lo. Tal fato demonstra que é essencial ter a garantia de que os usuários do dispositivo são quem eles dizem quem são e que têm as credenciais necessárias para acessar a informação necessária.

As questões de segurança na **IoT** podem ser resolvidas, por exemplo, aproveitando os padrões 3GPP, entidade responsável pelo mecanismo de autenticação de rede que faz parte das redes celulares. Dentro das redes de celular, são usados mecanismos de autenticação fortes, além de outros sistemas de segurança, como ao Cartão de Circuito Integrado Universal (UICC).

Fazendo uma breve pausa na sequência textual, o citado 3º Projeto de Parceria de Geração (3GPP) une sete organizações de desenvolvimento de padrões de telecomunicações (ARIB, ATIS, CCSA, ETSI, TSDSI, TTA, TTC), conhecidos como “Parceiros Organizacionais” e fornece a seus membros um ambiente estável para produzir os relatórios e especificações que definem as tecnologias 3GPP.

Agora, para que o processo de autenticação seja considerado confiável, é preciso fazer a associação direta com a camada de transporte (de acordo com os modelos de referência OSI ou TCP/IP), pois para que a comunicação com a camada de transporte seja mantida segura, são usados algoritmos criptográficos fortes.

Isso significa o uso de certificados para autenticação no lado do servidor e credenciais do usuário como senhas e *tokens* para autenticação no lado do cliente.

No caso de dispositivos autônomos, que geralmente são operados em áreas remotas, há a necessidade de proteger as credenciais do usuário de ambos os ataques de rede e ataques físicos. Isto pode ser obtido mantendo o ambiente de produção e ambiente de armazenamento seguros. No entanto, com configurações de segurança complexas, operações como gerenciamento da rede pode se tornar uma tarefa extremamente difícil e complexa, devido ao aumento do número de dispositivos **IoT** conectados.

A segurança dos dispositivos **IoT** é geralmente determinada de acordo com o propósito para os quais são usados. Em alguns ambientes, a autenticação e

integridade de dados é o suficiente para que os dispositivos e dados permaneçam seguros, mas em outros casos, são necessárias medidas adicionais de segurança.

Um dos elementos-chave de uma arquitetura **IoT** segura é ter uma identidade segura e forte para cada uma das suas entidades. No entanto, com alguns dispositivos, o suporte para algumas tarefas relacionadas à segurança é praticamente impossível, haja vista que os dispositivos **IoT** precisam consumir um grande número de recursos para suportar o mecanismo de segurança e é de conhecimento que o fator consumo de energia é um dos pontos cruciais para tais dispositivos.

A melhor solução para esses problemas é pelo uso da tecnologia GBA, pois emprega o mecanismo de geração de chaves limitadas no tempo. A tecnologia GBA (*Generic Bootstrapping Architecture*) suporta autenticação de dispositivos e segurança de comunicação na camada de transporte em redes celulares em todo o mundo.

Após a autenticação do serviço, as chaves podem ser usadas para configurar qualquer tipo de comunicação segura, como a sessão compartilhada TLS (*Transport Layer Security*) baseada em chave, entre o serviço e o cliente. Esses recursos podem ser alcançados por meio da tecnologia GBA, como uma forte autenticação e identificação, e como não há necessidade de interação com o usuário, os dispositivos M2M operam de forma autônoma.

É perceptível que o assunto relacionado com a autenticação de dispositivos **IoT**, embora complexo, é imprescindível para projetos futuros, porém como o escopo do presente texto é algo mais introdutório, é preciso investir em algo mais substancial e tecnicamente mais detalhado. Por esse motivo, após o conhecimento introdutório, aspectos de segurança, **APIs** e mecanismos de autenticação, o assunto a seguir está diretamente relacionado à esfera estratégica da solução.

4.6 Estratégias para a segurança

O primeiro passo para implementar a segurança deve ser a realização de uma avaliação que deve incorporar a implementação da **IoT** no perfil geral de risco da empresa. Para isso, serão apresentadas boas práticas que servirão como uma “lista

de checagem”, fazendo com que os riscos sejam reduzidos e os benefícios para a conexão de novos dispositivos sejam maximizados.

O primeiro passo é dar início a uma pesquisa minuciosa que auxiliará na identificação dos riscos suscetíveis da empresa, haja vista que cada implementação de **IoT** é sempre única. Um bom exemplo está relacionado com projetos de eficiência energética, pois mesmo no caso de duas empresas implementando um sistema **IoT** para tornar os seus edifícios mais eficientes em termos energéticos, as implementações dos sistemas nas duas organizações serão totalmente diferentes.

E como avaliar os riscos? Existe algum procedimento específico? Na verdade, existem boas práticas e algumas delas serão listadas a seguir em tópicos:

- Acompanhe as soluções **IoT**. Realize uma auditoria completa nos dispositivos, redes, protocolos de comunicação e aplicativos. É sempre bom estar ciente do número de dispositivos **IoT** presentes na organização.
- Determine as vulnerabilidades de segurança para cada um dos elementos pertencentes ao projeto, pois em vez dos próprios dispositivos, é bom avaliar também as redes e protocolos de comunicação, as bases de dados e aplicativos, e qualquer outra rede com a qual a rede **IoT** pode interagir.
- Mapeie os piores cenários. Tenha certeza da noção do que pode acontecer no caso de cada um dos dispositivos falhar ou estar comprometido.
- Determine se é possível isolar os dispositivos de **IoT** e os dados de algumas redes, pois em alguns casos é possível operar o tráfego de modo separado, mas em outros, a integração é mandatória. Um exemplo disso são os sensores e sistemas HVAC (*Heating, ventilation and air conditioning*), já que esses podem ser operados em redes separadas da rede principal, isolando-os dos aplicativos e redes internas da empresa. O objetivo por trás disso é minimizar ao máximo a exposição do banco de dados.
- Determine a sensibilidade dos dados de cada dispositivo de **IoT**. É sempre bom estar ciente de como os dados são gerados, agregados ou transmitidos pelos vários dispositivos **IoT**.

Depois dessas considerações sobre a avaliação dos riscos, haverá condições de resolver um outro problema da segurança dentro do escopo da **IoT**, a verificação de que as informações e os dispositivos conectados estão protegidos ou não.

A maioria das medidas tradicionais de segurança de TI é voltada para proteger as informações contra roubo, exposição e danos. Diante disso, não é suficiente a preocupação com a disponibilidade da informação. Por exemplo, se o sensor fizer parte de um monitor de saúde usado por um paciente em particular, os criminosos podem roubar esses dados. Nesse caso, os dados devem ser adequadamente protegidos pelo uso de medidas de segurança como criptografia, *firewalls*, ferramentas de rede e outras ferramentas necessárias.

Em vez de gerar dados, os dispositivos **IoT** também interagem com os dispositivos no mundo real, por exemplo, para controlar o fluxo de eletricidade ou água. Isso explica o motivo ser necessário considerar tanto as preocupações de segurança operacional quanto a segurança da informação.

Sempre que se estiver determinando os riscos e as demandas de segurança para a empresa, é imprescindível também determinar os controles de segurança esperados. Um bom exemplo disso ocorre quando as informações do cartão de crédito dos clientes de uma empresa são roubadas ou expostas. Nesse caso, existem penalidades que podem acarretar até no fechamento negócio em médio prazo. Do mesmo modo, se um dispositivo **IoT** específico for manipulado de modo a causar danos físicos, suas consequências podem ultrapassar aquelas associadas à violação das informações da organização, acarretando danos irreversíveis.

4.7 Algumas boas práticas

Após o entendimento sobre como os aspectos relacionados com a segurança são fundamentais para o bom funcionamento de aplicações **IoT**, é também importante utilizar boas práticas para a sua manutenção. Seguindo essa linha, serão apresentados alguns dos pontos mais relevantes.

Uma forma de manter a solução segura contra os ataques que violam os dispositivos eletrônicos é a de utilizar um microcontrolador que começará a executar os códigos a partir da memória interna e imutável. No entanto, nem todas as

configurações do dispositivo têm a capacidade de suportar isso. O software que foi armazenado no controlador é geralmente considerado inerentemente confiável, já que é impossível para qualquer atacante para modificá-lo, por estar contido na memória “não gravável” do tipo ROM.

Além disso, a memória flash armazenada internamente no microcontrolador pode ser usada para armazenamento de software de raiz de confiança, se houver segurança adequada. Você pode ter uma memória flash declarada não modificável uma vez que o software tenha sido escrito a ele, ou um mecanismo de autenticação apropriado foi implementado de forma a garantir que apenas os indivíduos autorizados escrevam o software memória flash.

Se o software inicial for modificado e sem controle, não haverá garantia de confiança, e neste caso, significa que é o software que será executado primeiro, assim que o microcontrolador estiver ligado. Tal fato exige confiabilidade inerente a este software, que se tiver alguma confiabilidade, então poderá ser usado para a verificação da assinatura do aplicativo antes de renunciar ao controle do microcontrolador.

Quanto ao fornecedor do hardware, cada dispositivo que tenha sido conectado à rede, deve-se garantir o mínimo necessário para que o respectivo fornecedor esteja autorizado a executar uma atualização para o software de *firmware* do dispositivo. No entanto, como esta atualização é contínua e criptografada, devem ser feitas verificações de modo a garantir que só são recebidas atualizações dos fornecedores autorizados.

O fator senha precisa também ser avaliado, pois é importante evitar o uso de senhas padrão, haja vista que hackers e outros invasores geralmente se aproveitam das senhas padrão para obter acesso aos dispositivos **IoT**. Por esse motivo, tais senhas devem ser desativadas e os usuários devem criar senhas únicas e seguras que também devem ser mantidas de modo seguro.

No que tange ao termo *backdoors*, bastante conhecido como uma técnica de ataque utilizada por vírus, dentro do contexto da **IoT**, alguns dispositivos têm alguns pontos de entrada ocultos ou conhecidos que os atacantes podem aproveitar para prejudicar a aplicação. É sempre bom garantir que os dispositivos conectados não possuam esses pontos de entrada. Pode-se dizer o mesmo sobre a utilização de

serviços ou portas auxiliares, se um dispositivo não for capaz de suportar as funções de um determinado serviço, não devem ser oferecidos na rede.

Por fim, deve ser avaliado se o fabricante apresenta um suporte via fórum e informações de contato. Seja um fórum de suporte ou detalhes de contato devem ser fornecidos pelo fornecedor e que o operador ou cliente pode usar para contatá-los caso ocorra algo estranho.

CONCLUSÃO

Dentro do escopo de plataformas utilizadas dentro do ecossistema de **IoT**, foram apresentadas algumas soluções corporativas, as suas características, aspectos fortes e fracos, vantagens competitivas, além de potenciais aplicações no mundo real.

Os modelos emergentes para entrega de aplicativos e infraestrutura são claramente mais dinâmicos, distribuídos e diversificados do que nunca. Não importa o nome, se é computação em nuvem, virtualização ou data centers definidos por software, o gerenciamento de segurança e conformidade deve evoluir para ter sucesso nesses ambientes massivamente escalonáveis e de rápida volatilidade.

Essa evolução exige organização sob demanda de controles de segurança por meio de camadas de automação e os ambientes devem oferecer escalabilidade e capacidade para funcionar em qualquer lugar, independentemente da infraestrutura utilizada. Com isso vem a obrigatoriedade da ativação de **APIs** em vários níveis, servindo como força motriz como ponto principal para que a escalabilidade, confiabilidade e disponibilidade funcionem em conjunto.

Analisando cada um dos exemplos de plataformas citadas, fica o seguinte questionamento: será que existe a melhor? A resposta certa seria: depende das necessidades e demandas do cliente, pois é preciso antes de tudo fazer alguns apontamentos (*check list*) e criar indicadores, de modo ponderado, para ter, ao final, a escolha mais assertiva, adequada e customizada.

O fato é que em um mercado altamente competitivo, as empresas que queiram se posicionar estrategicamente devem trabalhar dentro destas características principais: interoperabilidade com padrões abertos, escalabilidade, personalização e segurança, acima de tudo.

Aproveite para procurar novas plataformas e investigar se elas se encaixam dentro das necessidades de sua empresa, pois é um ótimo exercício para o aprendizado deste complexo mundo tecnológico conectado.

EMENDAS

REFERÊNCIAS

CONVERGÊNCIA DIGITAL. Internet das Coisas: qualifique as suas expectativas para ter resultados. **Convergência Digital**, 30 ago. 2017. Disponível em: <[Internet das Coisas: qualifique as suas expectativas para ter resultados – ConvergenciaDigital](#)> Acesso em: 12 ago. 2022.

CLOUDFARE. Inside the infamous Mirai IoT Botnet: A Retrospective Analysis. 2017. Disponível em: <<https://blog.cloudflare.com/inside-mirai-the-infamous-iot-botnet-a-retrospective-analysis/>>. Acesso em: 9 ago. 2021.

DOJOT. **Site Institucional**. 2020. Disponível em: <[Documentação da dojot — documentação dojot v0.7.1 \(dojotdocs.readthedocs.io\)](#)>. Acesso em: 10 jun. 2020.

GARTNER aponta desafios e soluções para implementação correcta de IoT. Sisnema, s.d. Disponível em: <<https://sisnema.com.br/gartner-aponta-desafios-e-solucoes-para-implementacao-correcta-de-iot>>. Acesso em: 9 ago. 2021.

GARTNER. **Gartner says 4.9 billion connected ‘things’ will be used in 2015**. 2014. Disponível em: <<http://www.gartner.com/newsroom/id/2905717>>. Acesso em: 10 jun. 2020.

HPE. **Universal IoT Platform**. 2020. Disponível em: <https://www.hpe.com/emea_europe/en/solutions/iot-platform.html>. Acesso em: 12 jun. 2020.

IDC. **IDC Forecasts \$1.2 Trillion in Worldwide Spending on Digital Transformation Technologies in 2017**. 2017. Disponível em: <<https://www.idc.com/getdoc.jsp?containerId=prUS42327517>>. Acesso em: 10 jul. 2020.

SIEMENS. **The cloud-based, open IoT operating system for digital transformation**. 2020. Disponível em: < [White paper \(siemens.com\)](#)>. Acesso em: 10 out. 2024.

MIRAI. **Inside the infamous Mirai IoT Botnet: A Retrospective Analysis**. 2017. Disponível em: <[Inside the infamous Mirai IoT Botnet: A Retrospective Analysis \(cloudflare.com\)](#)>. Acesso em: 15 jul. 2020.

SAMSUNG. **Samsung apresenta sua visão da Internet das Coisas mais ampla e inteligente para simplificar a vida das pessoas**. 09 jan. 2018. Disponível em: <<https://news.samsung.com/br/samsung-apresenta-sua-visao-da-internet-das-coisas-mais-ampla-e-inteligente-para-simplificar-a-vida-das-pessoas>>. Acesso em: 12 ago. 2022.

SIEMENS. **Siemens cria organização de usuários globais do MindSphere**. 07 fev. 2018. Disponível em: < [Siemens cria organização de usuários globais do MindSphere | Press Brazil](#) >. Acesso em: 12 ago. 2022.